ARCHITECTURE DECISION RECORD

ADR 003: Parser de XML e Mitigação de Vulnerabilidades XXE

Status: Aprovado
Data: 16/10/26
Decisores: João Pedro Pellegrini de Almeida

1. Contexto e Problema

O sistema recebe arquivos XML de notas fiscais (NF-e e CT-e) enviados pelos usuários. Não se pode confiar que todo arquivo é inofensivo. Se o parser for mal configurado, alguém pode esconder dentro do arquivo uma instrução maliciosa para ler arquivos internos do servidor ou travar o sistema. Esse ataque se chama XXE. Como a chave da nota também vira o identificador da entrega, uma falha aqui afetaria a segurança e a confiabilidade dos dados.

2. Decisão

- Utilizar a biblioteca fast-xml-parser, que não busca arquivos nem endereços externos.
- Desligar a expansão de entidades, para que o parser nunca obedeça instruções escondidas.
- Recusar qualquer arquivo com `<!DOCTYPE` ou `<!ENTITY`. Notas fiscais verdadeiras não usam isso.
- Definir limites: só arquivos `.xml`, com tamanho máximo de 5 MB e tempo máximo de leitura.
- Conferir o conteúdo após a leitura, verificando se a estrutura é de uma NF-e/CT-e e se a chave de 44 dígitos é válida.
- Em caso de erro, devolvemos uma mensagem simples, sem mostrar o conteúdo do arquivo.
- Escrever os testes com XMLs maliciosos que precisam ser recusados, rodando a cada Pull Request.
- A versão da biblioteca ficará fixada e será monitorada (Dependabot e `npm audit`).

3. Consequências

Positivas	Negativas / Riscos
• Fecha as portas mais comuns de ataque na importação de XML. • Recusar o arquivo suspeito logo na entrada é simples e fácil de testar. • A conferência da chave impede que dados errados cheguem ao banco. • Os testes provam que a proteção funciona e continua funcionando.	• A biblioteca não confere o arquivo contra o modelo oficial (XSD), então a checagem da estrutura é manual e pode deixar passar algum detalhe. • Um XML legítimo com DTD seria recusado. • Dependemos de uma biblioteca de terceiros e precisamos acompanhar atualizações de segurança. • O limite de tamanho pode barrar arquivos muito grandes.